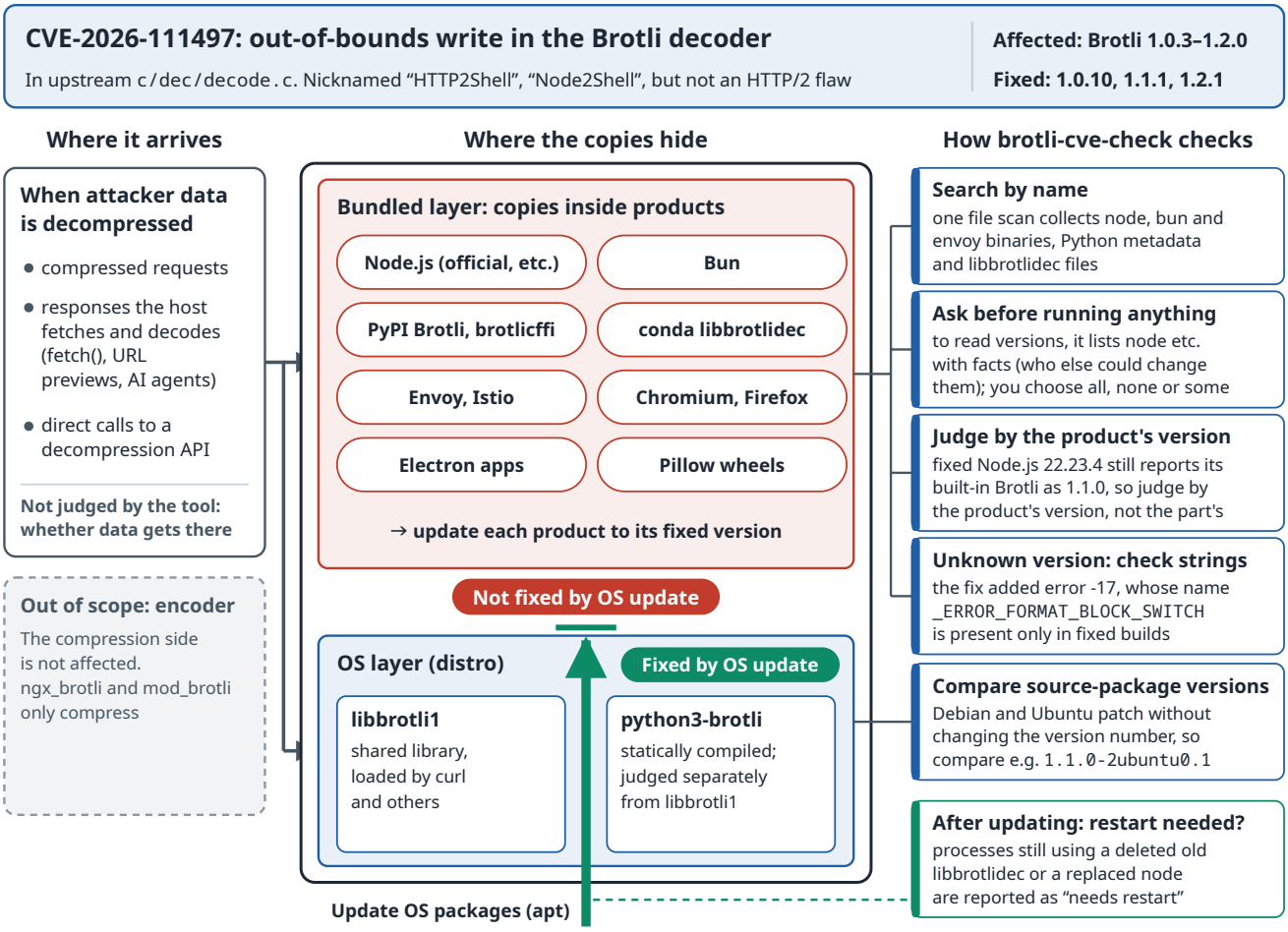
Fig. 01 What we checked, and how CVE-2026-111497



How to read this page

1. **The flaw is on the decompression side (the decoder) and is reached when attacker data is decompressed.** Data can arrive as a compressed request, as a response the host fetches and decodes automatically (`fetch()`, URL previews, crawlers, AI agents), or through a direct call to a decompression API. The tool **inventories** the copies; whether data can reach them is for you to judge. Upstream fixed it on 2026-10-21 (GHSA-9v8h-qqgm-4m35).
2. **Bundled copies need each product's own update** (**updating the OS does not fix them**). Fixed versions include Node.js 22.23.4 / 24.22.1 / 26.12.1, Bun 1.4.4 and PyPI Brotli 1.2.1. The string check was verified on self-built Brotli 1.2.0 / 1.2.1, official Node.js binaries and PyPI wheels; a build whose error-name table was stripped is reported as `VENDORED_COPY` (needs review), never as fixed. The OS packages are fixed on both Ubuntu (USN-8956-1) and Debian (DLA-4855-1, DSA-6582-1).
3. **Read-only, and it never says "safe". It shows the facts; you decide.** It writes only to standard output and `--output`, and uses neither the network nor attack data. Found programs run only if chosen, with one version argument (`--version` etc.), from `/`, with an empty environment, stdin closed, a time limit and capped output. Without a terminal, `--yes` or `--no-exec` is required. The report lists what ran and what did not. `EXPOSURE` is a hint of a path, not a vulnerability. It does not check for intrusion.

Updating the OS fixes only the OS's copy, so bundled copies must be found and told apart one by one, by version and by strings.

Next step Verify the SHA256, run `sudo bash brotli-cve-check`, read the facts before choosing what may run, then act on "Needs update" and "Needs restart" first.

Fig. 01 | made 2026-10-27 (advisory data of the same date) Sources: GHSA-9v8h-qqgm-4m35, USN-8956-1, brotli-cve-check v0.1.0 docs